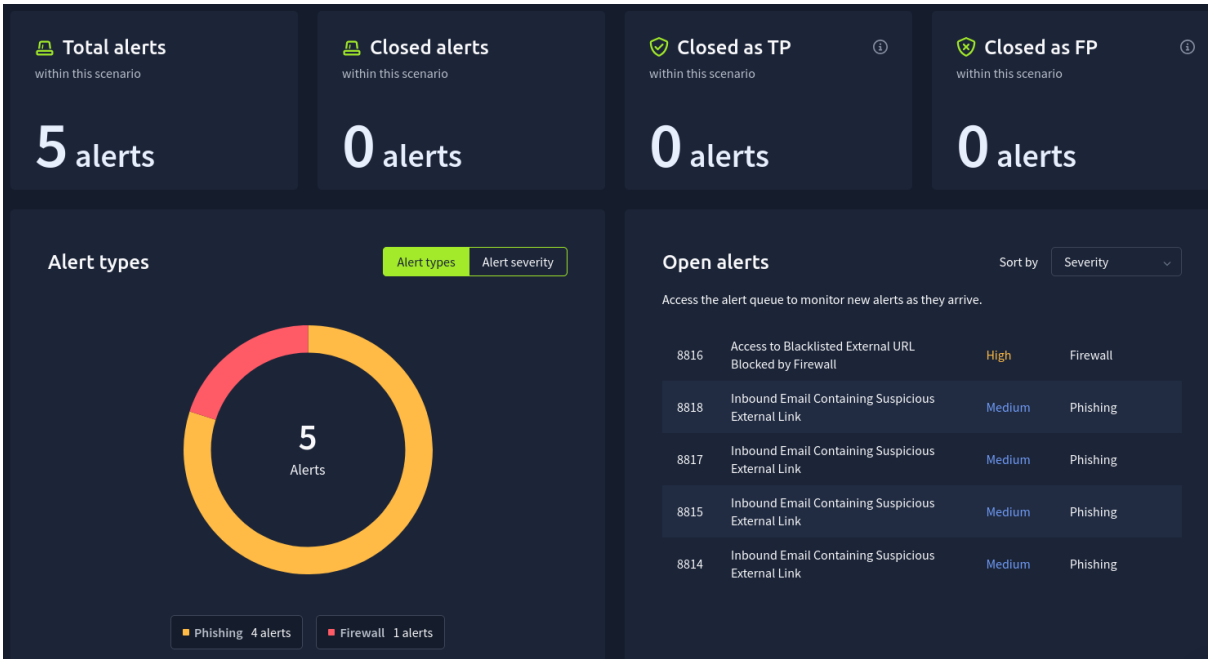
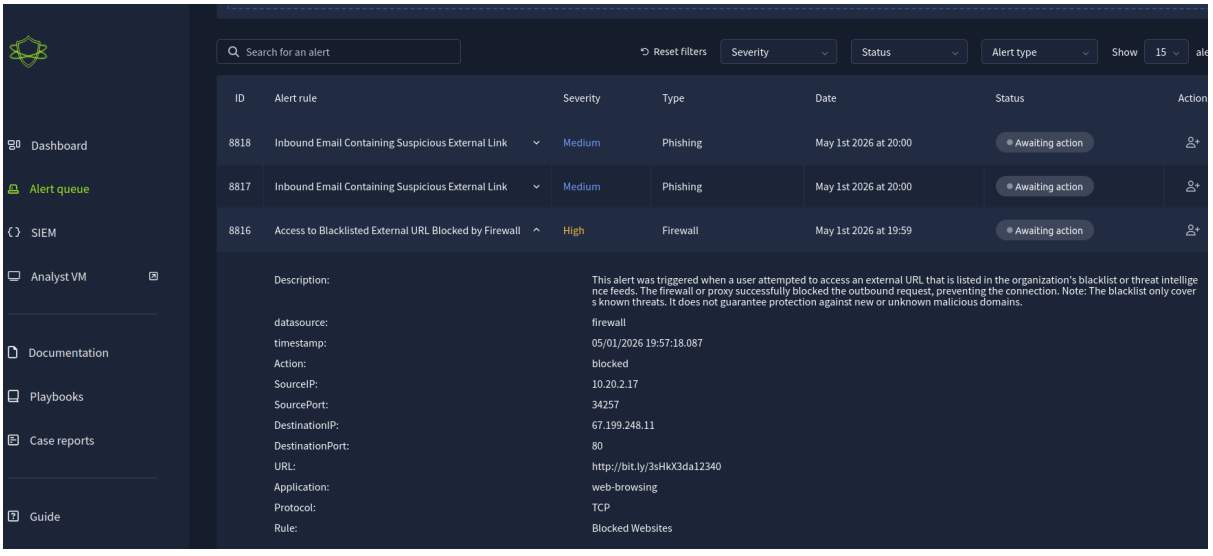
Microsoft Sentinel na prática

Nesse cenário sou um analista SOC L1 reponsável em monitorar e analisar alertas em tempo real no Microsoft Sentinel (SIEM), correlacionar dados e classificar como True Positive (TP) ou False Positive (FP), decidir se escalo ou não, e escrever relatório.



Alerta 1 (ID 8816)

Na fila de alertas, decidi analisar por severidade (High):
8816 - Access to Blacklisted External URL Blocked by Firewall - High - Firewall



Descrição:

Este alerta foi acionado quando um usuário tentou acessar um URL externo que consta na lista negra da organização ou nos feeds de inteligência de ameaças. O firewall ou proxy bloqueou com sucesso a solicitação de saída, impedindo a conexão. Observação: a lista negra abrange apenas ameaças conhecidas. Ela não garante proteção contra domínios maliciosos novos ou desconhecidos.

datasource: firewall

timestamp: 05/02/2026 13:00:10.865

Action: blocked

SourceIP: 10.20.2.17

SourcePort: 34257

DestinationIP: 67.199.248.11

DestinationPort: 80

URL: http://bit.ly/3sHkX3da12340

Application: web-browsing

Protocol: TCP

Rule: Blocked Websites

RESUMO DO ALERTA

- **IP interno:** 10.20.2.17
- **Usuário (pela tabela):** Hannah Harris (RH)
- **Destino:** 67.199.248.11
- **URL:** bit.ly (encurtador)
- **Ação: blocked ✔**
- **Regra:** Blocked Websites
- **Severidade:** High

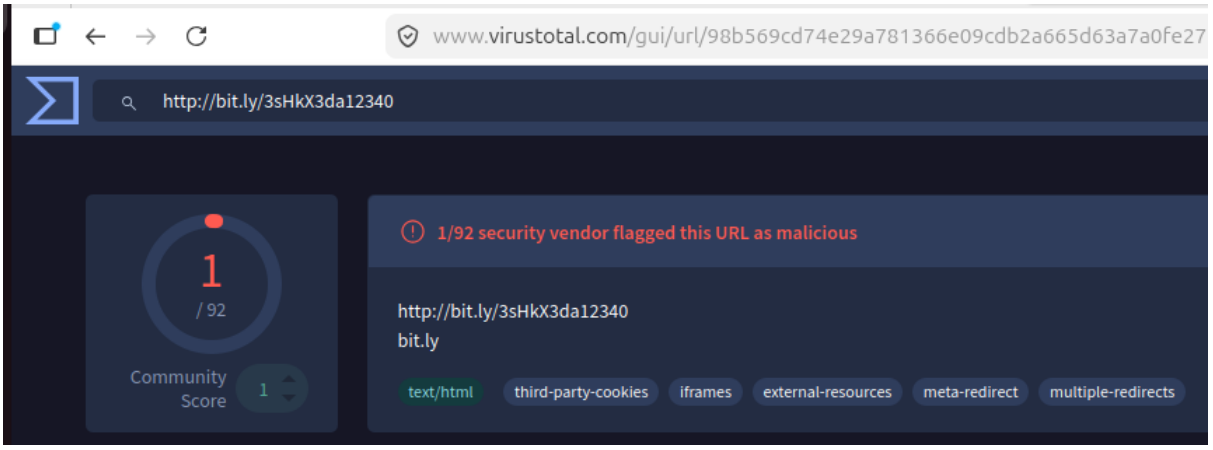
ANÁLISE REAL

O que aconteceu:

- Usuário tentou acessar um link encurtado (bit.ly)
- Esse tipo de link é MUITO usado em phishing
- O firewall reconheceu como suspeito
- **Bloqueou antes de qualquer conexão acontecer**

1 - Validação do IOC

O link foi analisado em plataformas de Threat Intelligence, confirmando que se trata de um recurso malicioso, frequentemente utilizado em campanhas de phishing.

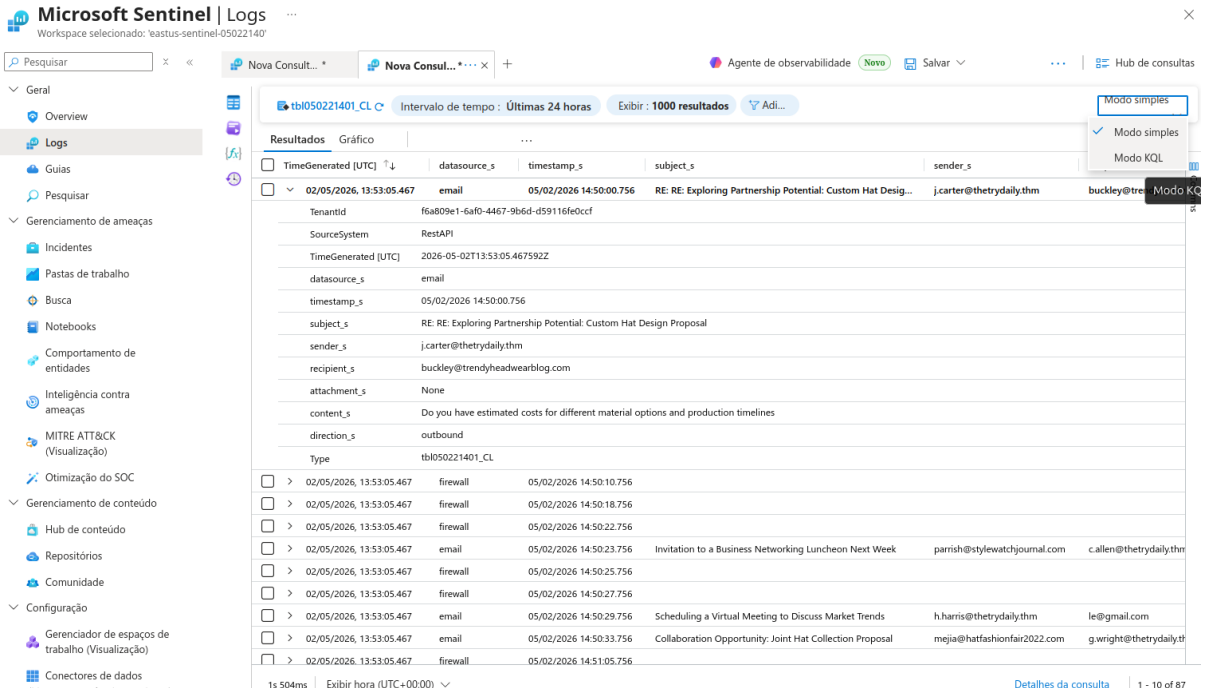


O alerta é apenas o ponto de partida. Eu sempre valido no SIEM para obter contexto adicional, como frequência, origem e impacto da atividade. Por isso vamos analisar algumas coisas no Microsoft Sentinel (SIEM) utilizando a consulta KQL.

2 - Investigação no SIEM

No Microsoft Sentinel, irei analisar a tabela de logs para validar o contexto do alerta.

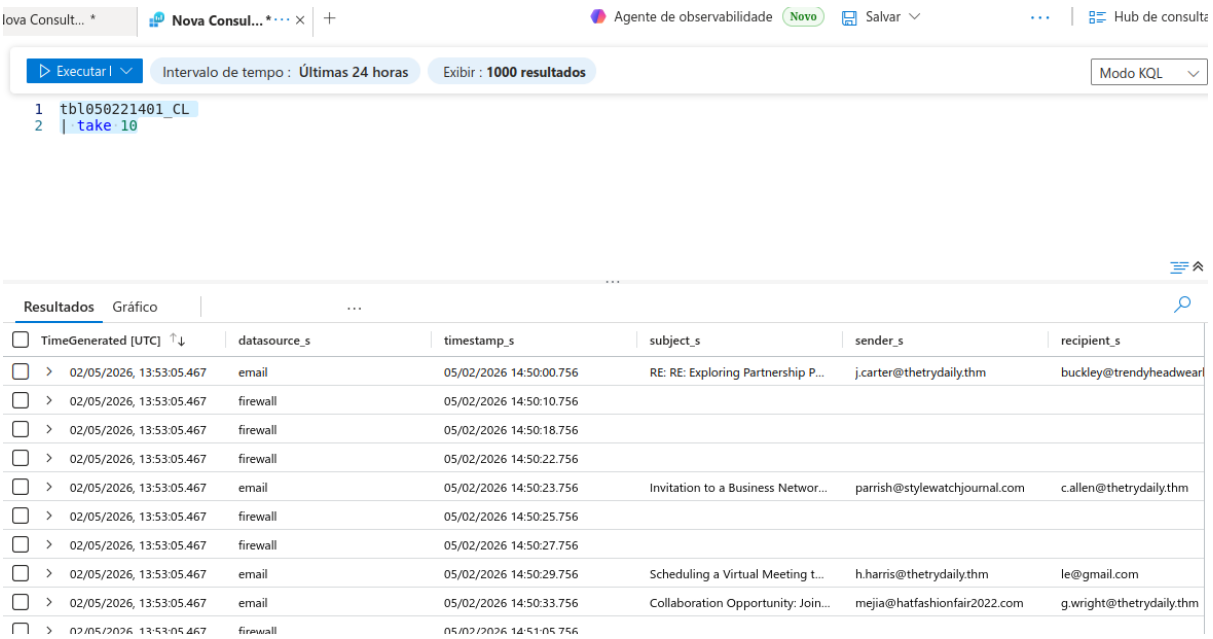
Primeiramente seleciono a tabela, logs personalizados, executo e escolho o modo KQL:



Faço essa consulta para ver 10 registros dessa tabela

tbl050221401_CL

| take 10



TimeGenerated [UTC]	datasource_s	timestamp_s	subject_s	sender_s	recipient_s
02/05/2026, 13:53:05.467	email	05/02/2026 14:50:00.756	RE: RE: Exploring Partnership P...	j.carter@thetrydaily.thm	buckley@trendyheadwear
02/05/2026, 13:53:05.467	firewall	05/02/2026 14:50:10.756			
02/05/2026, 13:53:05.467	firewall	05/02/2026 14:50:18.756			
02/05/2026, 13:53:05.467	firewall	05/02/2026 14:50:22.756			
02/05/2026, 13:53:05.467	email	05/02/2026 14:50:23.756	Invitation to a Business Networ...	parrish@stylewatchjournal.com	c.allen@thetrydaily.thm
02/05/2026, 13:53:05.467	firewall	05/02/2026 14:50:25.756			
02/05/2026, 13:53:05.467	firewall	05/02/2026 14:50:27.756			
02/05/2026, 13:53:05.467	email	05/02/2026 14:50:29.756	Scheduling a Virtual Meeting t...	h.harris@thetrydaily.thm	le@gmail.com
02/05/2026, 13:53:05.467	email	05/02/2026 14:50:33.756	Collaboration Opportunity: Join...	mejia@hatfashionfair2022.com	g.wright@thetrydaily.thm
02/05/2026, 13:53:05.467	firewall	05/02/2026 14:51:05.756			

A análise confirmou que o evento está relacionado a logs de firewall.

3 - Análise do Evento

O alerta indica:

- Ação: blocked
- URL maliciosa (bit.ly)
- Origem interna (10.20.2.17)

Isso confirma que:

✔ houve tentativa de acesso
✔ o firewall bloqueou com sucesso

CLASSIFICAÇÃO

True Positive

Motivo:

A tentativa de acesso a um recurso malicioso foi identificada e bloqueada pelo firewall, indicando comportamento potencialmente malicioso ou risco ao ambiente.

ESCALONAMENTO

Não escalado

Motivo:

- Conexão bloqueada com sucesso
- Nenhuma evidência de impacto
- Nenhuma comunicação estabelecida

RELATÓRIO FINAL

Período da atividade:
05/01/2026 19:57:18

Lista de entidades afetadas:

- Usuária: Hannah Harris (h.harris@thetrydaily.thm)
- Host: win-3457
- IP de origem: 10.20.2.17
- IP de destino: 67.199.248.11
- URL: http://bit.ly/3sHkX3da12340

Motivo para classificação como True Positive:
Esta atividade foi classificada como **True Positive**, pois um usuário da rede interna tentou acessar uma URL externa presente em listas de bloqueio da organização. A URL utiliza um serviço de encurtamento (bit.ly), frequentemente associado a campanhas de phishing e redirecionamentos maliciosos. Além disso, o destino está identificado em fontes de threat intelligence como malicioso, confirmando o risco da atividade.

Motivo para não escalonar:
O alerta **não requer escalonamento**. Apesar da tentativa de acesso a um recurso malicioso, o firewall bloqueou a requisição com sucesso, impedindo qualquer comunicação com o host externo. Não foram identificadas evidências de comprometimento ou atividades adicionais suspeitas no ambiente.

Ações corretivas recomendadas:

- Orientar a usuária sobre riscos relacionados a phishing e links suspeitos
- Monitorar possíveis novas tentativas de acesso a URLs maliciosas
- Garantir que as soluções de proteção de endpoint estejam ativas e atualizadas
- Manter o monitoramento de eventos semelhantes para identificação de possíveis campanhas

List of Attack Indicators:

- IP de origem: 10.20.2.17
- IP de destino: 67.199.248.11
- URL: http://bit.ly/3sHkX3da12340
- Protocolo: TCP
- Porta de destino: 80
- Aplicação: web-browsing

Alerta 2 (ID 8814)

Descrição: Este alerta foi acionado por um e-mail recebido que contém um ou mais links externos devido a características potencialmente suspeitas. Como parte da investigação, verifique os registros do firewall ou proxy para determinar se algum endpoint tentou acessar os URLs no e-mail e se essas conexões foram permitidas ou bloqueadas.

Fonte de dados: e-mail

Data e hora: 05/04/2026 15:55:53.395

Assunto: Ação necessária: Finalizar seu perfil de integração

Remetente: onboarding@hrconnex.thm

Destinatário: j.garcia@thetrydaily.thm

Anexo: Nenhum

Conteúdo: Olá, Sra. Garcia,\n\nBem-vinda ao TheTryDaily!\n\nComo parte do seu processo de integração, por favor, conclua a configuração final do seu perfil para que possamos configurar seu acesso.\n\nPor favor, clique no link abaixo:\n\n<a href="https://hrconnex.thm/onboarding/15400654060/j.garcia">Configurar meu perfil</a>.\n\nCaso tenha alguma dúvida, entre em contato com a Equipe de Integração de RH.

Direção: entrada

O que temos:

- Tipo: **email inbound com link externo**
- Destinatário: **j.garcia**
- Assunto: onboarding
- Domínio: **hrconnex.thm**

Primeira análise:

Hipóteses:

Pontos legítimos

✔ fala de onboarding
✔ link parece corporativo (hrconnex.thm)
✔ sem encurtador (tipo bit.ly)
✔ linguagem normal (sem urgência exagerada)

Pontos suspeitos

✔ domínio externo (não é thetrydaily.thm)
✔ pede ação (clicar link)
✔ alerta foi gerado (algo chamou atenção do sistema)

Contexto importante

Email interno dizendo:

> "novo parceiro de HR (hrconnex.thm)"

Hipótese inicial

Isso provavelmente é atividade legítima (possível False Positive)

MAS… ainda não posso concluir

Primeira investigação:

1. Esse domínio é legítimo?

`hrconnex.thm`

Usando o VirusTotal, confirmo que não se trata de um link malicioso.

2. Houve tentativa de acesso ao link?

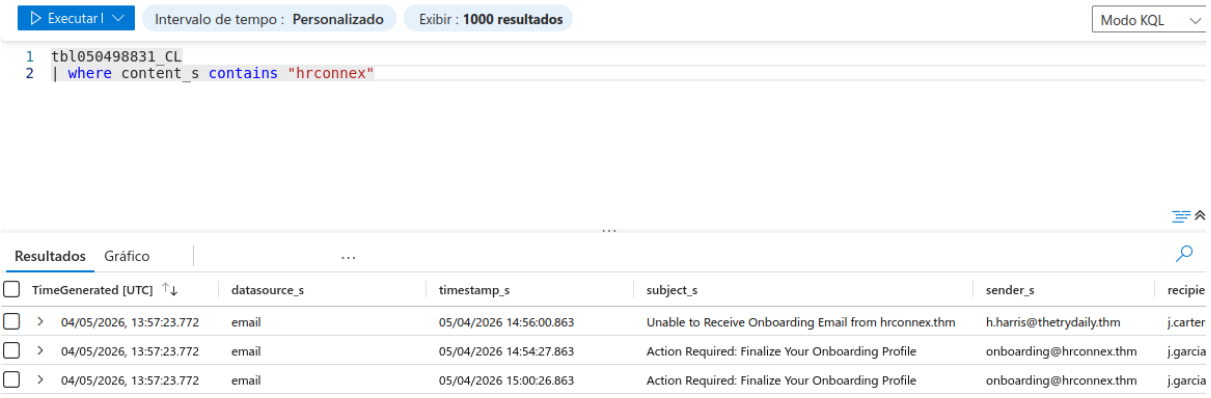
Verificar firewall / logs

INVESTIGAÇÃO NO SIEM

Buscar emails relacionados

tbl050243341_CL

| where content_s contains "hrconnex"



Aqui analisando melhor os emails consigo confirmar que se trata de emails trocados com parceiros de RH, então confirmo que não se trata de Phishing.

Identificar acesso ao link

Já imagino que o link foi acessado e por confirmar que o link era confiável e de um parceiro da empresa não preciso investigar isso.

✔ **False Positive**

Porque:

- domínio hrconnex.thm é legítimo
- existe contexto interno confirmando parceiro de RH
- conteúdo do email é coerente com onboarding
- não há indícios técnicos de phishing

✔ **Não escalonado**

Porque:

- não há ameaça real
- não houve impacto
- não há comprometimento
- atividade esperada no ambiente

Atividade legítima identificada. Sem evidência de comportamento malicioso ou necessidade de ação adicional.”

RELATÓRIO FINAL

Período da atividade:
05/04/2026 15:55:53

Lista de entidades afetadas:

- Usuária: Julia Garcia (j.garcia@thetrydaily.thm)
- Domínio: hrconnex.thm
- URL: https://hrconnex.thm/onboarding/15400654060/j.garcia
- Tipo de atividade: Email inbound com link externo

Motivos por classificar como False Positive:
A atividade foi classificada como **False Positive**, pois o domínio *hrconnex.thm* foi identificado como um parceiro legítimo de Recursos Humanos da organização, conforme evidenciado por comunicações internas. O conteúdo do email é consistente com processos legítimos de onboarding e não apresenta características típicas de phishing, como uso de encurtadores de URL, linguagem alarmista ou domínios suspeitos.

Além disso, verificações em fontes externas não indicaram que o domínio ou URL estejam associados a गतिविधes maliciosas.

Motivo para não escalonar:
O alerta **não requer escalonamento**, pois a atividade é legítima e esperada dentro do contexto organizacional.

Adicionalmente, não foram encontradas evidências de comportamento malicioso ou comprometimento associado ao evento.

Ações corretivas recomendadas:

- Revisar e ajustar a regra de detecção para reduzir falsos positivos relacionados a domínios confiáveis
- Considerar inclusão do domínio *hrconnex.thm* em listas de permissões (whitelisting), se aplicável
- Manter monitoramento contínuo para garantir que o domínio não seja comprometido futuramente

Lista de indicadores de ataque:

- Domínio: hrconnex.thm
- URL: https://hrconnex.thm/onboarding/15400654060/j.garcia
- Tipo: Email com link externo

Alerta 3 (ID 8815)

Este alerta foi acionado por um e-mail recebido que contém um ou mais links externos devido a características potencialmente suspeitas. Como parte da investigação, verifique os registros do firewall ou proxy para determinar se algum endpoint tentou acessar os URLs no e-mail e se essas conexões foram permitidas ou bloqueadas.

Fonte de dados: e-mail

Data e hora: 05/04/2026 18:19:10.095

Assunto: Seu pacote da Amazon não pôde ser entregue – Ação necessária

Remetente: urgents@amazon.biz

Destinatário: h.harris@thetrydaily.thm

Anexo: Nenhum

Conteúdo: Prezado(a) Cliente,\n\nNão foi possível entregar seu pacote devido a um endereço incompleto.\n\nPor favor, confirme suas informações de envio clicando no link abaixo:\n\nhttp://bit.ly/3sHkX3da12340\n\nCaso não recebamos sua resposta em até 48 horas, seu pacote será devolvido ao remetente.\n\nObrigado(a),\n\nEntrega da Amazon

Direção: Entrada

Agora sim estamos diante de um caso clássico de phishing (provável True Positive)

PASSO 1 — ANÁLISE INICIAL

O que chama atenção imediatamente:

Indicadores claros de phishing

- Remetente: **amazon.biz** (não é domínio oficial da Amazon)
- Uso de **encurtador (bit.ly)**
- Tom de urgência (“48 horas”)
- Tema comum de golpe (entrega de pacote)
- Link HTTP (não HTTPS)

CONCLUSÃO INICIAL

Isso é **ALTAMENTE suspeito**

Hipótese: **Phishing — provável True Positive**

PASSO 2 — O QUE PRECISO VALIDAR

1. Link é malicioso?
2. Houve tentativa de acesso?
3. Houve impacto?

PASSO 3 — INVESTIGAÇÃO

Validar o link

Já vi esse link antes:

bit.ly/3sHkX3da12340

Esse mesmo apareceu no alerta 1 (bloqueado pelo firewall)

ISSO É CRÍTICO

Isso conecta os alertas:

- Alerta 1 → tentativa bloqueada
- Alerta 3 → email phishing com mesmo link

Isso é **correlação de ataque**

Verificar se houve acesso

No seu cenário (limitado):

✔ SIEM → Não tenho acesso total

Acesso = **não confirmado**

CLASSIFICAÇÃO

✔ True Positive

Motivo:

- phishing claro
- IOC conhecido (bit.ly)
- engenharia social
- possível campanha

ESCALONAMENTO

✔ SIM

Por quê?

- tentativa de phishing ativo
- possível impacto em usuário
- link reutilizado (campanha)

RELATÓRIO FINAL

Período da atividade: 05/04/2026 18:19:10.095

Motivos por classificar como True Positive:
Esta atividade foi classificada como **True Positive**, pois o email apresenta múltiplos indicadores claros de phishing. O remetente utiliza um domínio não oficial (*amazon.biz*), divergente dos domínios legítimos da Amazon. O conteúdo emprega técnicas de engenharia social, incluindo senso de urgência e solicitação de ação imediata.

Além disso, o link presente no email utiliza um serviço de encurtamento (*bit.ly*), frequentemente explorado para ocultar destinos maliciosos. O mesmo URL já havia sido identificado em um alerta anterior como malicioso e bloqueado pelo firewall, confirmando sua associação com atividade suspeita e potencial campanha de phishing.

Motivo por escalonar:
O alerta **requer escalonamento**, pois representa uma tentativa ativa de phishing direcionada a um usuário interno. A reutilização do mesmo indicador (URL) em múltiplos eventos sugere a existência de uma campanha coordenada.

Mesmo sem evidência confirmada de acesso ao link, o risco potencial justifica investigação adicional e possível resposta a incidente para mitigar impactos.

Ações corretivas recomendadas:

- Bloquear o domínio *amazon.biz* e URLs associadas no firewall e/ou proxy
- Adicionar o link encurtado a listas de bloqueio e threat intelligence internas
- Notificar a usuária sobre a tentativa de phishing e orientar sobre boas práticas de segurança
- Realizar varredura no ambiente para identificar possíveis acessos ao mesmo indicador por outros usuários
- Revisar políticas de filtragem de email para reduzir exposição a campanhas similares

Lista de indicadores de ataque:

- Email remetente: urgents@amazon.biz
- Domínio suspeito: amazon.biz

- URL: http://bit.ly/3sHkX3da12340
- Técnica: Phishing (engenharia social)
- Protocolo: HTTP

Alerta 4 (ID 8817)

Descrição: Este alerta foi acionado por um e-mail recebido que contém um ou mais links externos devido a características potencialmente suspeitas. Como parte da investigação, verifique os registros do firewall ou proxy para determinar se algum endpoint tentou acessar os URLs no e-mail e se essas conexões foram permitidas ou bloqueadas.

Fonte de dados: e-mail

Data e hora: 05/04/2026 18:21:28.095

Assunto: Atividade de login incomum em sua conta Microsoft

Remetente: no-reply@m1crosoftsupport.co

Destinatário: c.allen@thetrydaily.thm

Anexo: Nenhum

Conteúdo: Olá C.Allen,\n\nDetectamos uma tentativa de login incomum em sua conta Microsoft.\n\nLocal: Lagos, Nigéria\n\nEndereço IP: 102.89.222.143\n\nData: 24/01/2025 06:42\n\nSe não foi você, proteja sua conta imediatamente para evitar acesso não autorizado.\n\n<a href="https://m1crosoftsupport.co/login">Revisar atividade</a>\n\nObrigado Você,\n\nEquipe de Segurança de Contas da Microsoft

Direção: entrada

O**utro clássico de phishing**.

PONTO CRÍTICO

Isso é uma técnica chamada:

✔ **typosquatting**

- microsoft.com ✔ legítimo
- **m1crosoftsupport.co - falso (usa "1" no lugar de "i")**

INDICADORES DE PHISHING

✔ domínio falso (m1crosoft)
✔ tentativa de urgência
✔ cenário comum (login suspeito)
✔ link externo
✔ engenharia social

HIPÓTESE

Phishing — provável True Positive

PASSO 2 — O QUE VALIDAR

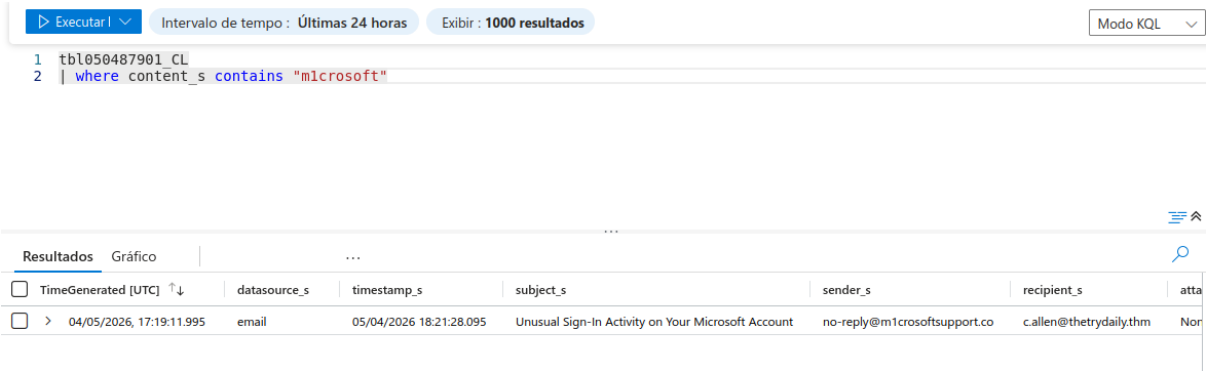
1. link é malicioso?
2. alguém acessou?
3. existe impacto?

PASSO 3 — INVESTIGAÇÃO

Procurar no SIEM

tbl050243341_CL

| where content_s contains "m1crosoft"



Procurar acesso

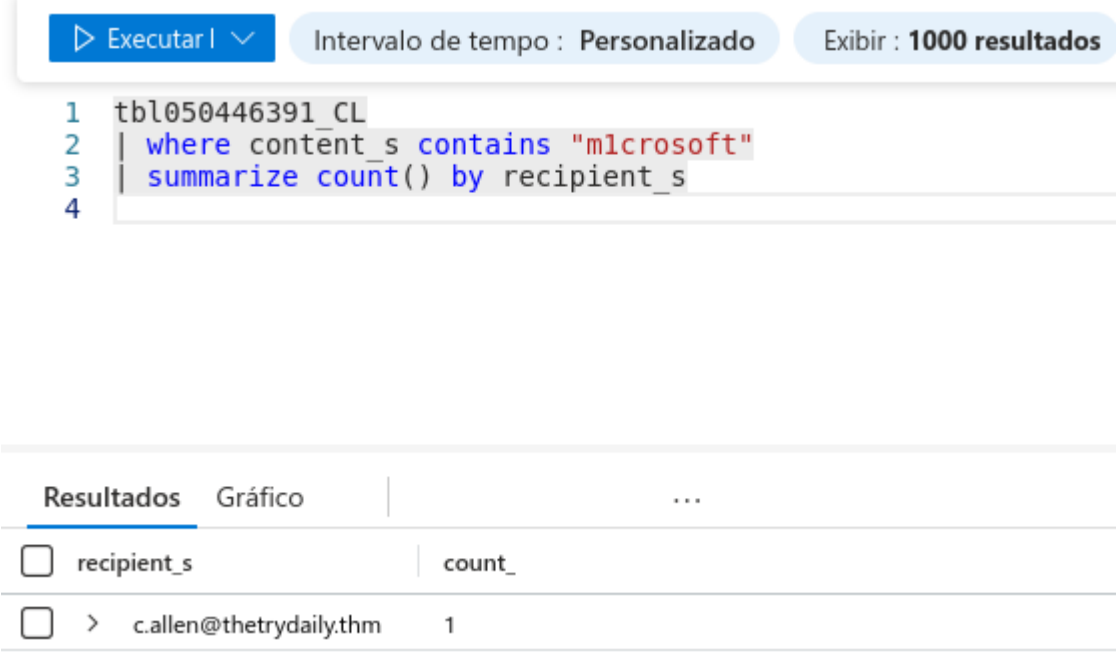
| where content_s contains "login"

QUERY 1 — VER SE OUTROS USUÁRIOS RECEBERAM

tbl050243341_CL

| where content_s contains "m1crosoft"

| summarize count() by recipient_s



Isso responde:

✔ foi direcionado

QUERY 2 — VER TODOS OS EMAILS DESSE REMETENTE

tbl050243341_CL

| where sender_s contains "m1crosoftsupport.co"

Isso mostra:

✔ campanha ativa
✔ múltiplas tentativas

QUERY 3 — BUSCAR POR PADRÃO DE PHISHING

tbl050243341_CL

| where content_s contains "sign-in"

Pode revelar:

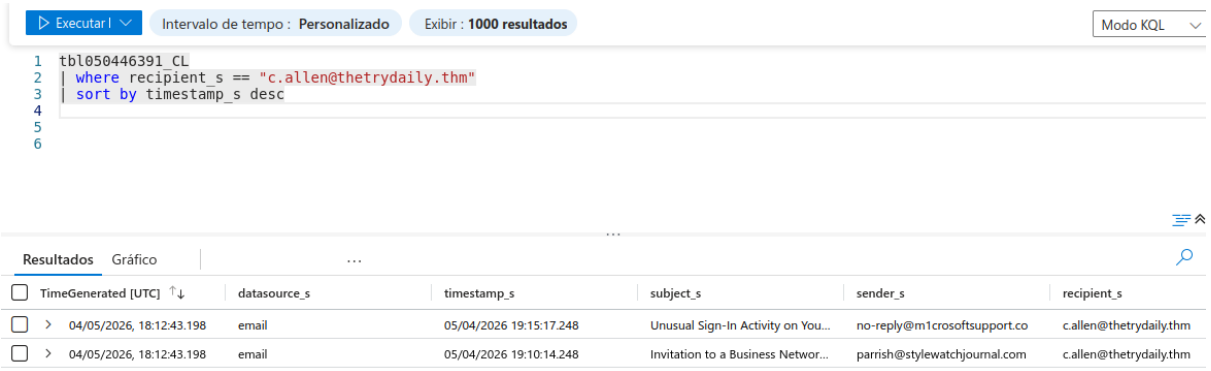
✔ outros phishing semelhantes

QUERY 4 — VER ATIVIDADE DO USUÁRIO

tbl050243341_CL

| where recipient_s == "c.allen@thetrydaily.thm"

| sort by timestamp_s desc



Tento ver:

✔ comportamento estranho
✔ múltiplos emails suspeitos

DECISÃO FINAL

✔ 1. Classificação: **True Positive**

Motivo:

- domínio falso (m1crosoftsupport.co)
- técnica de typosquatting
- tentativa de engenharia social (login suspeito)
- link externo malicioso

✔ **2. Escalonamento:** SIM

Por quê?

- tentativa ativa de phishing
- risco de comprometimento de credenciais
- usuário interno foi alvo direto
- possível campanha

RELATÓRIO FINAL

Período da atividade:
05/04/2026 18:21:28

Lista de entidades afetadas:

- Usuária: Charlotte Allen (c.allen@thetrydaily.thm)
- Host: win-3463
- IP interno associado: 10.20.2.25
- Remetente: no-reply@m1crosoftsupport.co
- Domínio suspeito: m1crosoftsupport.co
- URL: https://m1crosoftsupport.co/login

Motivo para classificação como True Positive:

Esta atividade foi classificada como **True Positive**, pois o email apresenta fortes indicadores de phishing. O domínio *m1crosoftsupport.co* utiliza técnica de **typosquatting**, imitando o domínio legítimo da Microsoft ao substituir a letra “i” pelo número “1”.

O conteúdo da mensagem explora engenharia social ao alegar atividade suspeita de login, induzindo o usuário a agir rapidamente para “proteger” sua conta. Esse tipo de abordagem é comumente utilizado em campanhas de roubo de credenciais.

Além disso, o email contém um link externo direcionando para uma página de login falsa, potencialmente utilizada para coleta de credenciais.

Motivo para escalonar:

O alerta **requer escalonamento**, pois representa uma tentativa ativa de phishing com potencial comprometimento de credenciais.

Mesmo não havendo evidências confirmadas de acesso ao link nos logs disponíveis, o risco associado à natureza do ataque justifica investigação adicional e possíveis ações de resposta a incidente.

Consultas adicionais no SIEM não identificaram eventos correlacionados ou múltiplas ocorrências, porém a ausência de evidências é limitada pela visibilidade restrita do ambiente.

Ações corretivas recomendadas:

- Bloquear o domínio *m1crosoftsupport.co* em firewall e/ou proxy
- Adicionar o domínio e URL às listas de threat intelligence internas
- Notificar a usuária sobre a tentativa de phishing
- Recomendar alteração de senha como medida preventiva
- Revisar e reforçar políticas de filtragem de email
- Monitorar o ambiente para identificar possíveis tentativas semelhantes

Lista de indicadores de ataque:

- Email remetente: no-reply@m1crosoftsupport.co
- Domínio suspeito: m1crosoftsupport.co
- URL: https://m1crosoftsupport.co/login
- Técnica: Phishing (typosquatting + engenharia social)
- IP mencionado no email: 102.89.222.143

Alerta 5 (ID 8818)

Descrição:

Este alerta foi acionado por um e-mail recebido que contém um ou mais links externos devido a características potencialmente suspeitas. Como parte da investigação, verifique os registros do firewall ou proxy para determinar se algum endpoint tentou acessar os URLs no e-mail e se essas conexões foram permitidas ou bloqueadas.

Fonte de dados: e-mail

Data e hora: 05/04/2026 19:15:45.248

Assunto: Ação necessária: Finalizar seu perfil de integração

Remetente: onboarding@hrconnex.thm

Destinatário: j.garcia@thetrydaily.thm

Anexo: Nenhum

Conteúdo: Olá, Sra. Garcia,\n\nBem-vinda ao TheTryDaily!\n\nComo parte do seu processo de integração, por favor, conclua a configuração final do seu perfil para que possamos configurar seu acesso.\n\nClique no link abaixo:\n\n<a href="https://hrconnex.thm/onboarding/15400654060/j.garcia">Configurar meu perfil</a>.\n\nCaso tenha alguma dúvida, entre em contato com a Equipe de Integração de RH.

Direção: entrada

PASSO 1 — COMPARAÇÃO COM ALERTAS ANTERIORES

Esse email é **idêntico aos anteriores de onboarding**:

- remetente: `onboarding@hrconnex.thm`
- domínio: `hrconnex.thm`
- link: onboarding legítimo
- mesma usuária: `j.garcia`

INSIGHT IMPORTANTE

Agora não é só “parece legítimo”

Já tenho:

✔ validação prévia (alerta 2)
✔ contexto interno (parceiro HR)
✔ múltiplas ocorrências iguais

INTERPRETAÇÃO CORRETA

✔ fluxo normal de onboarding
✔ reenvio automático / lembrete
✔ comportamento esperado

POR QUE GEROU ALERTA?

O sistema só viu:

✔ email externo
✔ link clicável

mas **não entende contexto de negócio**

CLASSIFICAÇÃO

✔ **False Positive**

ESCALONAMENTO

Não escalonar

Este alerta corresponde a um e-mail de boas-vindas repetido de uma plataforma de RH terceirizada previamente verificada (hrconnex.thm). A atividade está de acordo com os processos legítimos da empresa e não representa uma ameaça à segurança.

RELATÓRIO FINAL

Período da atividade:
05/04/2026 19:15:45

Lista de entidades afetadas:

- Usuária: Julia Garcia (j.garcia@thetrydaily.thm)
- Domínio: hrconnex.thm
- URL: https://hrconnex.thm/onboarding/15400654060/j.garcia
- Tipo de atividade: Email inbound com link externo

Motivo por classificar como False Positive:

A atividade foi classificada como **False Positive**, pois o email é proveniente de um domínio legítimo (*hrconnex.thm*), previamente identificado como parceiro oficial de Recursos Humanos da organização.

O conteúdo da mensagem é consistente com processos reais de onboarding, sem apresentar indicadores típicos de phishing, como domínios suspeitos, uso de encurtadores de URL ou linguagem de urgência.

Além disso, eventos semelhantes já foram analisados anteriormente e confirmados como parte de um fluxo legítimo de comunicação, indicando que este alerta representa apenas um reenvio ou continuidade do processo de integração.

Motivo por não escalonar:

O alerta **não requer escalonamento**, pois a atividade é legítima e esperada dentro do ambiente corporativo.

Não foram identificados sinais de comportamento malicioso, comprometimento ou risco associado ao evento.

Ações corretivas recomendadas:

- Ajustar regras de detecção para reduzir falsos positivos relacionados a domínios confiáveis
- Considerar inclusão do domínio *hrconnex.thm* em listas de permissões (whitelisting)
- Manter monitoramento contínuo para garantir que o domínio não seja comprometido futuramente

Lista de indicadores de ataque:

- Domínio: hrconnex.thm
- URL: https://hrconnex.thm/onboarding/15400654060/j.garcia
- Tipo: Email com link externo (atividade legítima)

Sobre o autor

Paulo Cesar é formado em Segurança da informação pela Universidade Nove de Julho e apaixonado por Cibersegurança! Mais informações e contato:

linkedin.com/in/paulo-cesar-security